

UNIVERSIDAD MAYOR DE SAN ANDRÉS

Carrera de Informática – Seguridad de la Información



Proyecto: Explotación de Módulos de Autenticación Web - Escudo Pet Spa

Nombre del informe: Informe de Pentesting – posible explotación de seguridad y funcionalidad de módulos de autenticación en entorno local

Materia: Taller Técnico Superior

Analista de seguridad: Limachi Tapia Guillermo

Estudiante revisado: Luis Gael Alvarez Portugal

Fecha: 31/05/26

Clasificación del documento: Académico / Confidencial

INFORME EJECUTIVO DE VULNERABILIDADES (RV)

Fase de Ejecución, Explotación y Mitigación

Operación Escudo Pet Spa

1. RESUMEN EJECUTIVO

El presente informe documenta la fase de ejecución teórica, simulación ofensiva y evaluación de vulnerabilidades del sistema “Pet Spa”, considerando los módulos correspondientes a Administrador, Recepción, Groomer y Cliente.

La evaluación fue realizada mediante análisis de superficie de ataque observable en material audiovisual y revisión conceptual basada en metodologías OWASP Top 10, simulación ofensiva y evaluación de malas prácticas de seguridad.

Debido a limitaciones del entorno, las pruebas fueron desarrolladas bajo un enfoque de explotación hipotética controlada, orientado a identificar posibles escenarios de compromiso, manipulación de lógica de negocio, inyección de código, abuso de carga de archivos y deficiencias en trazabilidad y auditoría.

Los hallazgos identificados evidencian riesgos asociados a:

- Ausencia de CAPTCHA y MFA.
- Validaciones insuficientes en formularios.
- Posibles vulnerabilidades XSS y SQL Injection.
- Deficiencias en RBAC.
- Falta de controles robustos de auditoría.
- Riesgo de saturación de bases de datos.

- Posibles fallas de integridad en inventario y sesiones.

2. OBJETIVOS

2.1 Objetivo General

Evaluar la seguridad ofensiva del sistema Pet Spa mediante simulación de explotación, validación de controles de autenticación, pruebas de lógica de negocio y análisis de vulnerabilidades críticas visibles en la superficie de ataque.

2.2 Objetivos Específicos

- Simular pruebas ofensivas sobre autenticación y sesiones.
- Evaluar posibles escenarios de SQL Injection y XSS.
- Analizar la seguridad de carga de archivos.
- Verificar debilidades de auditoría y trazabilidad.
- Evaluar posibles fallas de lógica de negocio.
- Identificar riesgos de escalación de privilegios.
- Verificar políticas de cifrado y almacenamiento de contraseñas.

- Proponer medidas de mitigación y remediación.

3. ALCANCE

Módulos Evaluados

- Login
 - Registro de clientes
 - Panel Administrador
 - Groomer
 - Recepción
 - Gestión de usuarios
 - Inventario
 - Agenda de reservas
 - Auditoría y logs
 - Gestión de sesiones
 - Formularios dinámicos
 - Carga de archivos
- Recuperación de contraseña

4. LIMITACIONES DEL ENTORNO

El análisis realizado corresponde a una evaluación y práctica limitada, ejecutada sobre un repositorio clonado en un entorno local (laptop personal). No se contó con acceso a un proyecto desplegado en producción, servidores reales, arquitectura distribuida, APIs funcionales, tráfico HTTP activo ni bases de datos en operación.

Por tanto:

- No fue posible realizar explotación activa sobre un sistema en producción.
- No se pudo interceptar tráfico ni tokens JWT provenientes de un entorno real.
- No se validaron vulnerabilidades en infraestructura distribuida ni mediante payloads activos.
- Sí fue posible utilizar algunas herramientas en entorno controlado para simular ataques y evaluar vectores ofensivos de manera hipotética.

Las conclusiones corresponden a simulaciones ofensivas técnicamente plausibles basadas en la superficie de ataque observable y en pruebas locales realizadas sobre el repositorio clonado.

5. METODOLOGÍA

Metodología Utilizada

- Reconocimiento pasivo
 - Análisis de superficie de ataque
 - Evaluación OWASP Top 10
 - Simulación ofensiva
 - Evaluación RBAC
 - Threat Modeling
 - Simulación de explotación lógica
 - Revisión de malas prácticas
- Evaluación de autenticación y sesiones

6. EJECUCIÓN DE PRUEBAS OFENSIVAS

6.1 Pruebas de Lógica de Negocio (Agenda e Inventario)

Vulnerabilidad Evaluada

Posible manipulación de reservas, capacidad de agenda e inconsistencias de inventario.

Tipo de Ataque

- Manipulación lógica
- Parameter tampering
- Business Logic Abuse

Superficie de Ataque

- Agenda de reservas
- Inventario
- Carrito de servicios
- Formularios internos

Simulación de Ataque

Se evaluó la posibilidad de:

- Registrar múltiples reservas excediendo la capacidad permitida.
- Alterar cantidades de productos o servicios.
- Modificar subtotales antes del envío a WhatsApp/Telegram.
- Alterar consumo de insumos del Groomer.

La ausencia visible de validaciones backend y controles estrictos permite inferir viabilidad teórica de manipulación lógica de negocio.

Posible Exfiltración o Impacto

- Corrupción de inventario.
- Pérdida financiera.
- Alteración de precios.
- Inconsistencia operativa.
- Manipulación de registros internos.

Nivel de Criticidad

Alto

Mitigación

- Validaciones server-side.
- Recalcular subtotales únicamente en backend.
- Control de concurrencia.
- Restricciones de capacidad.
- Logs transaccionales.

6.2 Inyección y Sanitización (SQLi y XSS)

Vulnerabilidad Evaluada

Posible SQL Injection y XSS persistente en formularios dinámicos.

Tipo de Ataque

- SQL Injection
- Stored XSS
- Reflected XSS

Superficie de Ataque

- Registro de mascotas.
- Fichas técnicas Groomer.
- Formularios dinámicos.
- Campos libres.

Simulación de Ataque

Debido a la ausencia visible de sanitización y validaciones backend, se simuló teóricamente la inserción de payloads maliciosos.

Payload SQLi

' OR '1'='1

Payload XSS

<script>alert('XSS')</script>

La superficie observada sugiere posible viabilidad de explotación bajo condiciones reales.

Posible Exfiltración o Impacto

- Acceso no autorizado a BD.
- Robo de información.
- Secuestro de sesiones.
- Ejecución de scripts persistentes.
- Manipulación de formularios.

Nivel de Criticidad

Alto

Mitigación

- Prepared Statements.
- ORM seguro.
- Sanitización de entradas.
- CSP Headers.
- Escape de caracteres especiales.

6.3 Seguridad en Carga de Archivos

Vulnerabilidad Evaluada

Posible carga de archivos maliciosos en galería “antes/después” y carnets de vacunas.

Tipo de Ataque

- File Upload Attack
- MIME Spoofing
- Double Extension Attack

Superficie de Ataque

- Upload de imágenes.
- Carga de carnets.
- Archivos multimedia.

Simulación de Ataque

Ante ausencia visible de controles robustos de validación:

- se simuló teóricamente carga de archivos con doble extensión,
- spoofing MIME,
- archivos polyglot,
- payloads ejecutables ocultos.

Ejemplo hipotético:

vacuna.php.jpg

Posible Exfiltración o Impacto

- Ejecución remota de código.
- Compromiso del servidor.
- Persistencia maliciosa.
- Robo de información.

Nivel de Criticidad

Alto

Mitigación

- Validación MIME real.
- Antivirus.
- Renombrado de archivos.
- Almacenamiento fuera del servidor web.
- Restricción de extensiones.

6.4 Auditoría de Logs y Trazabilidad

Vulnerabilidad Evaluada

Deficiencias en monitoreo y trazabilidad de eventos.

Tipo de Ataque

- Log Tampering
- Log Injection
- Evasión de auditoría

Superficie de Ataque

- Logs.
- Panel administrativo.
- Sistema de auditoría.

Simulación de Ataque

Se evaluó teóricamente la capacidad del sistema para registrar:

- ¿Quién?, ¿Cuándo?, ¿Desde dónde? Y ¿Qué acción realizó?

Se identificó que varios sistemas dependen únicamente de logs internos sin SIEM centralizado.

Posible Exfiltración o Impacto

- Eliminación de evidencias.
- Encubrimiento de actividad maliciosa.
- Respuesta tardía a incidentes.

Nivel de Criticidad

Medio

Mitigación

- SIEM centralizado.
- Logs inmutables.
- Integridad criptográfica.
- Correlación de eventos.

6.5 Manipulación de Sesión

Vulnerabilidad Evaluada

Posible secuestro o persistencia indebida de sesiones activas.

Tipo de Ataque

- Session Hijacking
- Replay Attack
- Session Fixation

Superficie de Ataque

- Login.
- Gestión de sesiones.

- Tokens de autenticación.

Simulación de Ataque

La ausencia visible de controles avanzados de sesión permite inferir viabilidad teórica de:

- reutilización de tokens,
- persistencia de sesión,
- secuestro de sesión,
- cierre forzado antes del timeout esperado.

Posible Exfiltración o Impacto

- Acceso no autorizado.
- Suplantación de identidad.
- Persistencia maliciosa.

Nivel de Criticidad

Alto

Mitigación

- Rotación de tokens.
- Expiración corta.
- Cookies HttpOnly/Secure.
- MFA.

6.6 Privacidad de Datos Sensibles

Vulnerabilidad Evaluada

Posible exposición de información sensible a perfiles no autorizados.

Tipo de Ataque

- IDOR
- Escalación horizontal
- Broken Access Control

Superficie de Ataque

- Panel administrativo.
- Roles.
- Gestión de usuarios.

Simulación de Ataque

La debilidad observada en RBAC y roles inconsistentes permite inferir riesgo teórico de acceso indebido a:

- teléfonos,
- direcciones,

- historial de clientes,
- información privada.

Posible Exfiltración o Impacto

- Fuga de datos personales.
- Violación de privacidad.
- Acceso indebido a información sensible.

Nivel de Criticidad

Alto

Mitigación

- RBAC robusto.
- Restricciones de acceso.
- Validación backend.
- Segmentación de privilegios.

6.7 Validación de Cifrado

Vulnerabilidad Evaluada

Evaluación del almacenamiento de contraseñas.

Tipo de Ataque

- Cracking Offline
- Rainbow Tables

Superficie de Ataque

- Base de datos.
- Sistema de autenticación.

Simulación de Ataque

Se identificaron distintos escenarios:

- bcrypt correctamente implementado,
- hashing no identificado,
- hashing potencialmente débil en entornos PHP/XAMPP.

Posible Exfiltración o Impacto

- Compromiso de credenciales.
- Reutilización de contraseñas.
- Acceso masivo no autorizado.

Nivel de Criticidad

Medio / Alto

(Dependiendo del algoritmo implementado)

Mitigación

- Argon2id.
- bcrypt actualizado.
- Salt aleatorio.
- MFA.

7. CLASIFICACIÓN DE CRITICIDAD

Nivel Alto

- SQL Injection teórico
- XSS persistente
- Session Hijacking
- Broken Access Control
- File Upload Attack
- Ausencia de MFA administrativo
- Manipulación lógica de negocio

Nivel Medio

- Logs débiles
- Ausencia de SIEM
- Password policies débiles
- Registro masivo de usuarios
- CAPTCHA ausente

Nivel Bajo

- Deficiencias visuales de validación
- Controles frontend insuficientes
- Inconsistencias menores de UX de seguridad

8. CONCLUSIONES GENERALES

En este contexto, fue posible identificar múltiples superficies de ataque con viabilidad teórica de explotación bajo escenarios reales. Las principales debilidades observadas corresponden a:

- Controles insuficientes de autenticación.
- Validaciones débiles en backend.
- Ausencia de mecanismos de protección contra automatización (anti-bot/anti-brute force).
- Deficiencias en la implementación de RBAC.
- Riesgos de inyección SQL y XSS.
- Capacidades limitadas de auditoría y monitoreo.

Aunque no fue posible ejecutar explotación activa real debido a las restricciones del entorno, la evidencia observable permite concluir que varios componentes presentan

condiciones potencialmente vulnerables frente a amenazas comunes descritas en el **OWASP Top 10**.

Se recomienda fortalecer los siguientes aspectos críticos de seguridad:

- Implementación obligatoria de **autenticación multifactor (MFA)**.
- **Validaciones robustas en backend** para prevenir manipulación de peticiones.
- **Sanitización estricta de entradas** para mitigar riesgos de inyección y XSS.
- **Monitoreo centralizado mediante SIEM** con integridad criptográfica de logs.
- **Segmentación estricta de privilegios** para reducir riesgos de escalamiento.

Las conclusiones corresponden a simulaciones ofensivas técnicamente plausibles, apoyadas en herramientas utilizadas en entorno controlado, y reflejan riesgos que podrían materializarse en un despliegue real si no se aplican las mitigaciones recomendadas.